

Fixes Applied — All Ways Transfers

This document summarises the fixes made in response to the code analysis report.

All changes were built and tested; the website's behaviour and features are unchanged

(only made safer and faster). Commit: `Fix security, performance & quality issues from code analysis`.

Security

#	Issue	What was fixed
H2	HTML injection in emails	Every value placed into an email template is now escaped/sanitised, so a customer can't inject markup or scripts into the emails you or they receive.
H4	No rate limiting	Login, registration, password reset and public booking-lookup endpoints now limit how many attempts an IP can make in a time window, blocking brute-force and abuse.
H5	Weak session cookies	Session cookies now use <code>SameSite=Lax</code> , only send <code>Secure</code> over HTTPS, and the server trusts the reverse proxy so this is detected correctly. Reduces session/CSRF risk.
M1 / M10	Guessable booking references & weak randomness	Booking reference numbers and internal IDs are now generated with cryptographically strong randomness, so they can't be guessed to view other customers' bookings.
M7	Health endpoint leaked infrastructure	<code>/api/health</code> no longer exposes the database host, connection status or schema publicly. Detailed diagnostics are available only with a private token (<code>HEALTH_DIAG_TOKEN</code>).
M8	Secrets & personal data in logs	The Stripe webhook secret is no longer logged, and verbose webhook logging containing customer data is now off by default (enable with <code>DEBUG_WEBHOOKS=true</code> only when troubleshooting).

Performance

#	Issue	What was fixed
M5	Everything loaded up-front	Pages are now code-split — visitors only download the landing page first, and the admin dashboard/other pages load on demand. Smaller, faster first load.
M6	No compression / caching	Responses are gzip-compressed, and fingerprinted assets are cached for a year while HTML and the service worker are never stale-cached (so deployments show up immediately).
M9	A database write on every request	The “last signed in” timestamp is now updated at most once every 15 minutes per user, in the background — far fewer database writes.

Quality / PWA / SEO

#	Issue	What was fixed
H1	Build output committed to git	The <code>dist/</code> build folder is no longer tracked in the repository (it's regenerated by the build).
H3 / H6 / L2	Outdated dependencies	Updated <code>drizzle-orm</code> , <code>nanoid</code> , <code>vitest</code> and applied security audit fixes.
M3 / M4	App install branded "Admin"	The installable app (PWA) manifest and service worker are now branded for the public booking site, with caching fixed so users never get a stale version.
L1	Unused demo page	Removed the unused <code>ComponentShowcase</code> page.
L3	Zoom disabled	Removed <code>maximum-scale=1</code> from the viewport so visitors can pinch-zoom (accessibility).
L4	Missing social/SEO tags	Added Open Graph, Twitter Card, canonical URL and favicon tags for better link previews and search.
L5	Mixed package managers	Removed the leftover <code>pnpm</code> lock/workspace files; the project uses <code>npm</code> .
L8	Generic package name	Renamed the package to <code>always-transfers</code> with a proper description.

New optional environment variables

These are **optional** — the app works without them:

- `HEALTH_DIAG_TOKEN` — set to enable detailed `/api/health?token=...` diagnostics.
- `DEBUG_WEBHOOKS=true` — set temporarily to enable verbose Stripe webhook logging when troubleshooting.

Verification

- Production build succeeds (`npm run build`).
- Type-check shows no new errors introduced by these changes.
- Unit tests pass (email, auth/logout, password-reset, etc.). Remaining failures in the sandbox are only because no live database is connected there — not code issues.